

# ADR-001 — Authentification par JWT signé + cookies httpOnly

- **Statut** : Accepté
- **Date** : 2026-04-27
- **Auteur** : Jean Baptiste MBA NDONG
- **Décideurs concernés** : Concepteur PNPI, futur RSSI ANINF
- **Référence code** : `backend/app/core/auth.py` ,  
`frontend/src/app/api/[...path]/route.ts`

## Contexte

La PNPI doit authentifier six profils d'utilisateurs très hétérogènes (ministre, directeur, instructeur, inspecteur, opérateur industriel, admin) sur trois clients : - une SPA Next.js 14 (poste fixe Cabinet, Direction, Instructeurs), - une application Flutter mobile (inspecteurs sur le terrain, parfois hors ligne), - des intégrations machine-à-machine (futurs API publics, RCCM, DGI).

Trois familles de solutions étaient envisagées :

1. **Sessions serveur opaques** (cookie de session, état stocké côté serveur, généralement Redis).
2. **JWT en localStorage** (pattern SPA fréquent).
3. **JWT signé véhiculé par cookie httpOnly + Secure + SameSite=Lax**, avec un proxy Next.js qui injecte le `Authorization: Bearer` côté serveur.

Contraintes clés : - Souveraineté : le backend tourne en territoire gabonais, ne peut pas dépendre d'un service tiers d'auth fédérée hors-CEMAC. - Mobile offline : les inspecteurs doivent pouvoir authentifier des actions hors connexion puis synchroniser. - XSS / CSRF : le périmètre fonctionnel manipule des décisions administratives (signature ATI, sanction). Toute exfiltration de token est inacceptable. - Audit : chaque action sensible doit être traçable à un utilisateur et un `token_id` unique.

# Décision

---

Nous retenons le **JWT signé HS512 / RS256** avec les caractéristiques suivantes :

- **Transport navigateur** : cookie `pnpi_access_token` `HttpOnly` , `Secure` , `SameSite=Lax` , durée 8h alignée sur `PNPI_ACCESS_TOKEN_EXPIRE_MINUTES=480` .
- **Transport mobile / API M2M** : header `Authorization: Bearer <jwt>` .
- **Refresh token séparé** stocké en cookie `httpOnly` distinct, durée 30 jours, rotation à chaque usage.
- **token\_id unique** dans la *claim* JWT pour permettre une révocation serveur (table `revoked_tokens` ).
- **Proxy Next.js** : `frontend/src/app/api/[...path]/route.ts` lit le cookie `httpOnly` et injecte le Bearer côté serveur — le navigateur ne voit jamais le token.
- **Politique de mot de passe** : `bcrypt`, 12 caractères minimum, maj/min/chiffre/spécial, hash via `passlib.CryptContext` .
- **CSRF** : middleware d'origine validé sur toutes les requêtes mutantes ( `backend/app/core/csrf.py` ).

# Conséquences

---

## Positives

- **XSS blindé** : un script injecté dans la SPA ne peut pas lire le cookie (`httpOnly`) ni l'exfiltrer.
- **Statelessness côté API** : le backend FastAPI peut scaler horizontalement sans réplication de session.
- **Mobile compatible** : Flutter utilise le Bearer header naturel de `package:dio` , pas d'adhérence au cookie.
- **Audit complet** : chaque JWT porte un `token_id` que l'audit ( `core/audit.py` ) loggue à chaque action sensible.
- **Indépendance** : aucune dépendance à un IdP étranger (Auth0, Cognito, Firebase). Conformité au critère de souveraineté demandé par le Cabinet.

## Négatives

- **Révocation moins immédiate** qu'une session serveur — atténuée par la durée courte (8h) + table `revoked_tokens` consultée par le middleware.

- **Complexité du proxy** : la couche Next.js doit être maintenue à jour (catch-all route). Tout endpoint nouveau doit passer par le proxy, sous peine de fuite du token côté navigateur.
- **Charge opérationnelle** : la rotation des secrets `PNPI_SECRET_KEY` doit être planifiée (au minimum annuelle, et à chaque suspicion de fuite).

## Suivi

- **2026-T2** : implémenter la rotation automatique de `PNPI_SECRET_KEY` via un *secret store* (HashiCorp Vault ou ANINF KMS).
- **2026-T3** : passer de HS512 à **RS256** (clé asymétrique) pour permettre à des tiers (RCCM, DGI) de vérifier les JWT sans partager le secret.
- **Revue trimestrielle** : audit des tentatives d'authentification anormales (rate limiter `core/rate_limiter.py` + alertes Prometheus).

## Comparables

---

- **France-Connect** : OIDC + JWT signés RS256, cookies httpOnly côté SP. Modèle équivalent.
- **Estonia X-Road** : JWT + mTLS pour M2M. Cible long terme PNPI/CEMAC.
- **Rwanda Irembo** : sessions serveur classiques — modèle écarté car non scalable au mobile et au M2M.

---

*Fin de l'ADR-001.*